Software Seguro

```
root@software-seguro:~# ./start_course.sh
```

Clase 7: Business Logic

Curso Profesional de Ciberseguridad Web y Ethical Hacking

Repaso Clase 6

Estructura de un JWT

Objetivos de la Sesión

Comprender las consecuencias de una falta de controles estrictos en el flujo de la aplicación y en el manejo de procesos concurrentes, permitiendo alterar el estado del sistema y evadir restricciones.

Business Logic

Las vulnerabilidades de lógica de negocio son fallos en el diseño y la implementación de los procesos legítimos de una aplicación. A diferencia de los ataques técnicos (como inyectar código malicioso en una base de datos o manipular el DOM), estas vulnerabilidades explotan las reglas del sistema. El atacante utiliza la aplicación exactamente como fue diseñada, pero encadena las acciones de una manera que los desarrolladores no previeron para obtener un beneficio indebido (por ejemplo, transferir fondos negativos para aumentar su saldo o saltarse el paso de pago en un carrito de compras).



Limitaciones de Business Logic

La principal dificultad para descubrir estos fallos radica en que el comportamiento malicioso se ve exactamente igual que el tráfico legítimo a nivel de red y de código.

- Invisibles para los Escáneres Automatizados (DAST/SAST): Las herramientas automatizadas buscan firmas conocidas y errores de sintaxis (como una comilla simple ' que rompe una consulta SQL). Un escáner no tiene la capacidad de entender que un usuario con rol "Cliente" no debería poder cambiar el estado de un pedido a "Enviado", porque ambas son peticiones HTTP válidas y bien formadas.
- Falta de Payloads Estándar: No existe un diccionario de payloads (como listas de fuzzing o diccionarios de fuerza bruta) que puedas inyectar para encontrar un fallo lógico. Cada explotación es única y está hecha a medida para el flujo específico de la aplicación objetivo.
- Requieren Contexto de Negocio: El auditor debe entender perfectamente cómo funciona la empresa. Si no sabes cuáles son las reglas, no puedes saber cuándo se están rompiendo.
- La Frontera entre "Feature" y "Bug": Muchas veces, lo que parece una vulnerabilidad puede ser una característica de diseño intencional. Por ejemplo, permitir que un usuario reserve 500 asientos de cine y los mantenga bloqueados en su carrito durante 15 minutos puede ser una denegación de servicio lógica, o simplemente la forma en que el negocio decidió manejar las reservas grupales.
-
- Dependencia del Análisis Manual y Proxy: La única forma fiable de detectar estos fallos es mapear manualmente la aplicación

Modelado del Comportamiento

El análisis de la lógica de negocio requiere un enfoque metódico donde primero entiendes las reglas, luego las rompes.

- **Reconocimiento y Mapeo:**
  Identificar Roles y Entidades
  Mapear la Máquina de Estados
  Listar Flujos Críticos

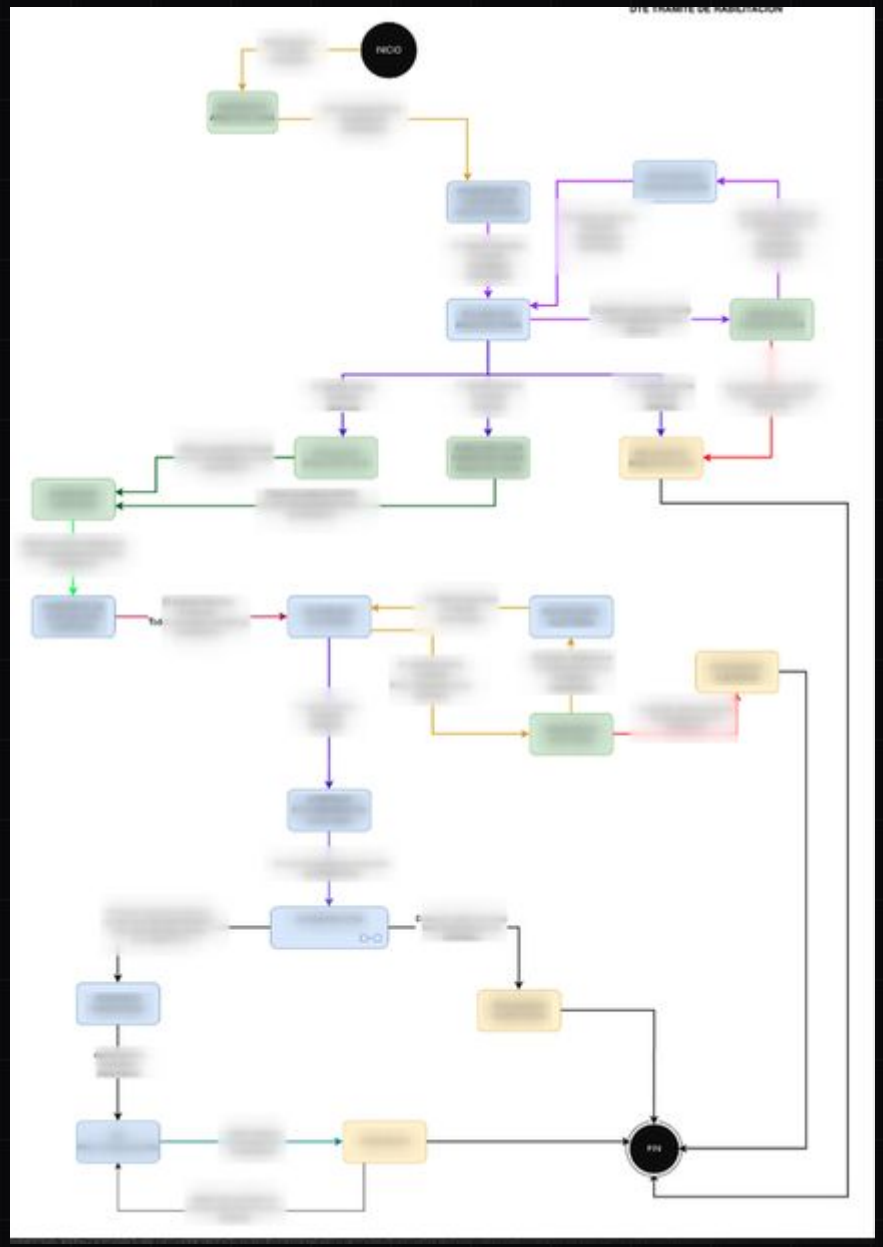
- **Análisis de Parámetros:**
  Manipulación de Precios
  Cantidades Inesperadas
  Alteración de Descuentos/Cupone

- **Pruebas de Concurrencia y Estados**
  - Inconsistentes:
  - Condiciones de Carrera (Race Conditions)
  - Límites de Uso (Rate Limiting Lógico)

- **Criterios de Aceptación (Validación Cruzada):**
  - Violación de Invariantes de Negocio:
  - Separación de Inquilinos (Tenant Isolation):

- **Manipulación de Flujos y Secuencias (Workflow Bypass)**
  - Navegación Forzada
  - Caída de Peticiones (Drop/Cancel)
  - Ataques de Replay en Fases

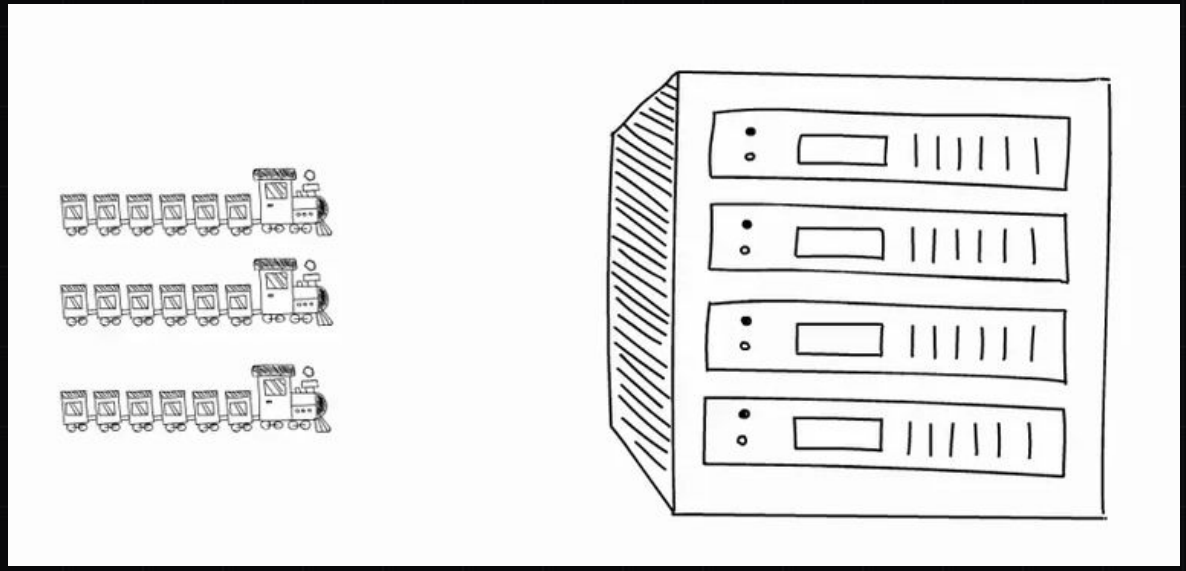
Historias de usuario y Maquina de estados



Race Condition

vulnerabilidad que ocurre cuando un sistema informático intenta realizar dos o más operaciones concurrentes (al mismo tiempo) sobre un recurso compartido, pero el resultado correcto del sistema depende de que esas operaciones se ejecuten en un orden secuencial estricto.

¿El problema? El mayor obstáculo al explotar vulnerabilidades de Race Condition: el Network Jitter (la fluctuación o latencia impredecible de la red).



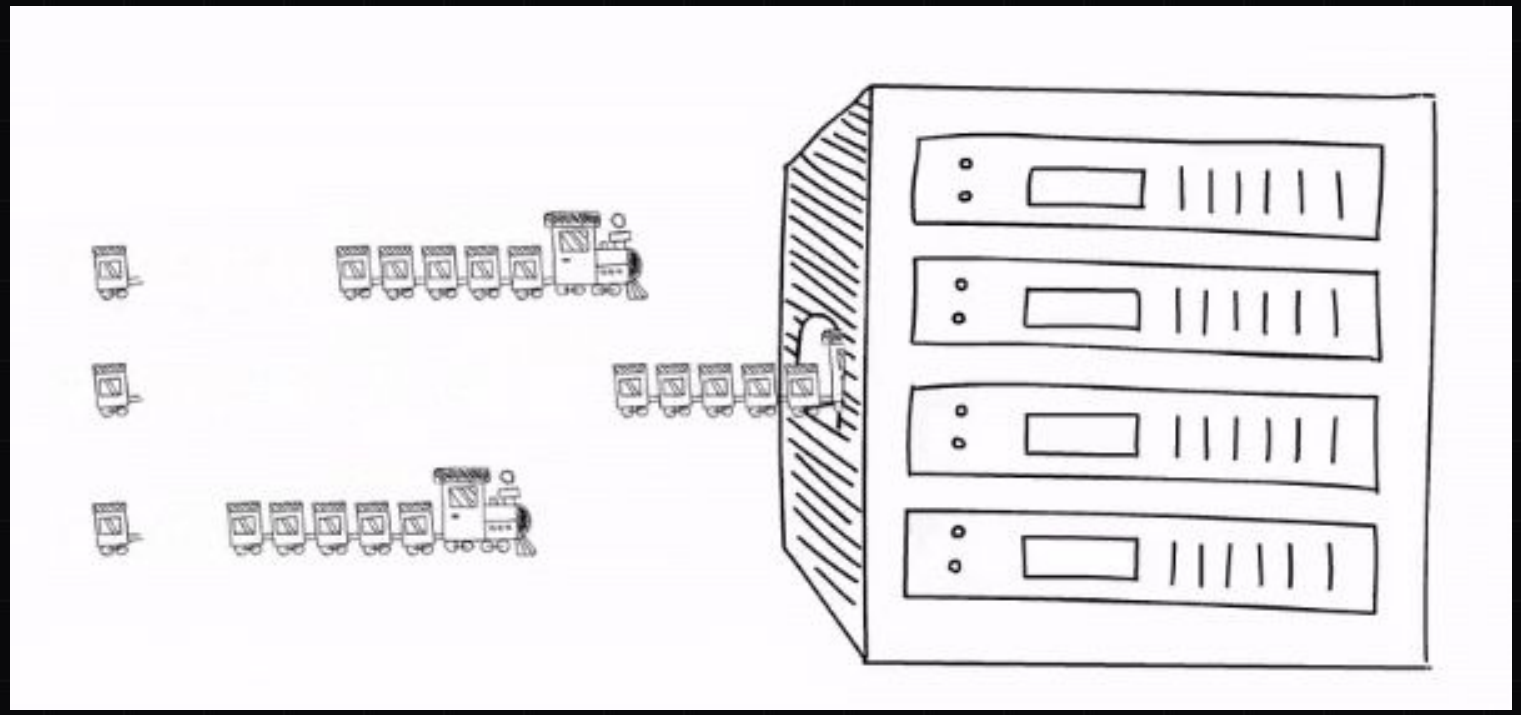
Last-Byte Synchronization

Sin flags de seguridad y Sin suficientes bits de entropía

Cómo funciona (El Ataque):

1. El atacante abre 20 conexiones TCP distintas con el servidor.
2. Envía el 99% de cada petición HTTP (todos los headers y casi todo el body), pero retiene intencionalmente el último byte de cada una.
3. El servidor recibe el 99% de la información, pero se queda "esperando" ese último byte para dar por recibida la petición y pasarla al backend (código de la aplicación).
4. Una vez que las 20 conexiones están en ese estado de "espera", el atacante envía el último byte de las 20 conexiones exactamente al mismo tiempo.

El Resultado: El último byte viaja rapidísimo porque es un paquete de red diminuto. El servidor recibe los 20 fragmentos finales simultáneamente y lanza las 20 ejecuciones en el backend al mismo tiempo, ignorando la latencia inicial de la red.



Single-Packet Attack

Cómo funciona (El Ataque):

1. El atacante prepara 20 o 30 peticiones HTTP completas (ej. 30 intentos de canjear un cupón).
2. Debido a cómo funciona HTTP/2 y los tamaños máximos de los paquetes de red (MTU - usualmente 1500 bytes), el atacante comprime y empaqueta las 30 peticiones HTTP en un solo paquete TCP a nivel de red (o en dos si es necesario).
3. El atacante envía ese único paquete TCP por la red.

El Resultado (Cero Jitter): Como todas las peticiones viajan físicamente juntas dentro del mismo sobre (el mismo paquete TCP), no sufren variaciones de latencia entre sí. Cuando el servidor recibe ese paquete y lo abre, se encuentra con 30 peticiones de golpe. El servidor las procesa en el mismo exacto microsegundo, garantizando una colisión de hilos (Race Condition) casi perfecta.

Controles

- Hacer cumplir la validación estricta del flujo de trabajo
- Implementar la validación de estado en el backend
- Realizar el modelado de procesos de negocio durante las revisiones de seguridad
- Aplicar controles de limitación de velocidad y anti-automatización
- Utilizar sistemas de auditoría y conciliación de transacciones
- Involucrar a los analistas de negocios en sesiones de modelado de amenazas

Demo

Asignación para el Hogar

Resolver y enviar los objetivos del Módulo III: Explotación Profunda: Lógica de Negocio y Validaciones

Ingresar a la plataforma de Software Seguro, en las opciones les aparecera el curso “Curso Profesional de Ciberseguridad Web y Ethical Hacking”, dentro del curso tienen los distintos módulos con sus objetivos que deberán enviar antes de la próxima sesión

¿Preguntas?

Fin de la Sesión 5.

https://softwareseguro.com.ar